

MEDICAL COMPANY POLICY

Healthcare Operations, Patient Data Protection & Compliance Policy

Document ID	MCP-001
Version	1.0
Effective Date	25 September 2026
Review Frequency	Annual or when regulations change
Owner	Compliance & Quality Department

1. Purpose

This policy establishes requirements for protecting patient information, maintaining safe healthcare operations, controlling access to company systems, managing incidents, retaining records, and maintaining compliance with applicable healthcare and data-protection requirements.

2. Scope

This policy applies to employees, contractors, interns, consultants, temporary staff, and authorized third parties who access company facilities, systems, medical records, patient information, or other confidential company information.

3. Patient Data Protection

Patient personal and medical information must be treated as confidential. Access must be limited to authorized personnel with a legitimate business or clinical need. Patient information must not be disclosed to unauthorized persons or used for purposes outside approved business, clinical, legal, or regulatory activities.

4. Data Storage and Encryption

Sensitive patient information stored on company systems must be protected using appropriate security controls. Sensitive information transmitted over external or untrusted networks must use approved encryption. Company-managed devices containing sensitive information must use access controls and security protections.

5. Access Control

User accounts must be unique to individual users. Access permissions must follow the principle of least privilege. Access rights must be reviewed periodically and removed promptly when an employee changes role or leaves the company. Shared accounts should not be used unless specifically approved and controlled.

6. Authentication and Passwords

Users must protect authentication credentials and must not share passwords. Strong authentication controls must be used where required by the sensitivity of the system or information. Lost or compromised credentials must be reported promptly to the appropriate security team.

7. Patient Record Management

Medical and patient records must be accurate, protected from unauthorized alteration, and maintained according to applicable retention requirements. Corrections to records must follow approved procedures and must preserve appropriate audit information.

8. Incident Reporting

Suspected unauthorized access, disclosure, loss of patient information, malware, security incidents, or other compliance events must be reported to the designated security or compliance team without unnecessary delay. The organization will assess incidents and follow applicable notification and escalation requirements.

9. Employee Training

Personnel who handle patient information or regulated systems must receive appropriate privacy, security, and compliance training. Training completion must be documented and refreshed periodically or when significant policy or regulatory changes occur.

10. Third-Party Access

Third parties that access patient information or company systems must be authorized and subject to appropriate contractual, confidentiality, security, and compliance requirements. Access must be limited to what is necessary for the approved service.

11. Data Retention and Secure Disposal

Records must be retained for the period required by applicable law, regulation, contractual obligations, and approved company schedules. When information is no longer required, it must be securely disposed of using an approved process appropriate to the media and sensitivity of the information.

12. Physical Security

Restricted areas containing patient records, medical equipment, servers, or sensitive information must have appropriate physical access controls. Visitors must be managed according to facility procedures and must not receive unsupervised access to restricted areas unless authorized.

13. Compliance Monitoring

The Compliance & Quality Department may conduct periodic reviews, audits, access reviews, training checks, and policy assessments. Identified gaps must be documented, assigned to responsible owners, and tracked until corrective action is completed or formally accepted through an approved risk process.

14. Corrective Actions

When a compliance gap is identified, the responsible department must define a corrective action addressing the root cause. Corrective actions should include an owner, target completion date, required evidence, and verification of completion. High-risk findings should receive priority review and escalation.

15. Policy Review

This policy must be reviewed at least annually and whenever significant changes occur in applicable regulations, company operations, technology, or identified risks. Approved changes must be communicated to affected personnel.

COMPLYAI Test Note

This document is a fictional sample company policy created for software testing and demonstration of compliance-gap analysis. It is not legal advice and should not be treated as an actual healthcare compliance policy.